

Exploring and Preventing Attack Paths with Defender for Cloud CSPM

Gregor Reimling
Thomas Naunheim



Gregor Reimling

Chief Azure Technologist
@adesso SE



Thomas Naunheim

Cyber Security Architect
@glueckkanja AG

Agenda

1. Introduction and adoption of CSPM
 2. Risk prioritization with Attack Path Analysis
 3. Data-aware security posture (DSPM)
 4. Adv. scenarios with XSPM and APIs
- 



Your experiences with CSPM?

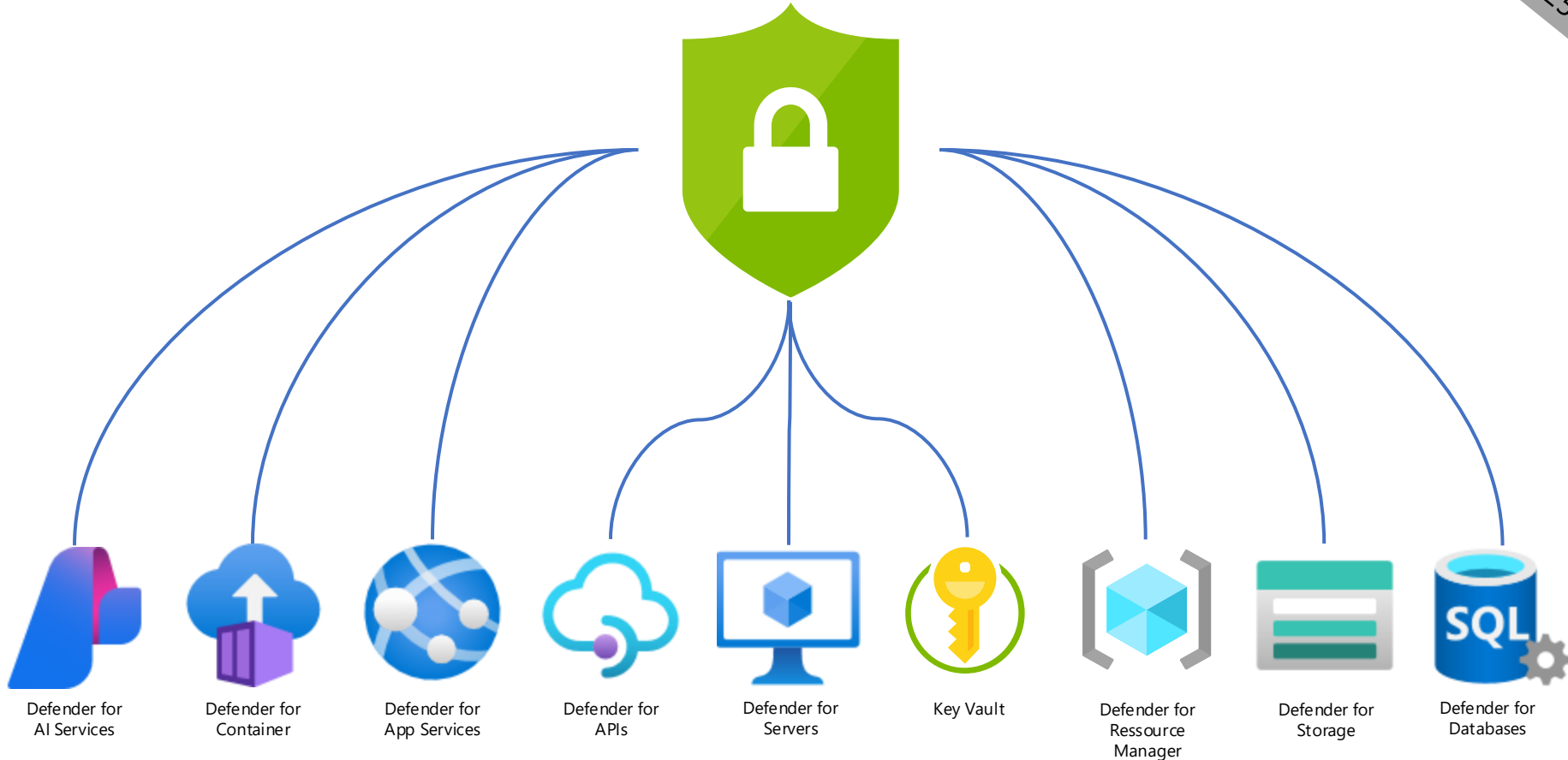
- Already in use (production)
- Evaluation or partly use
- Using 3rd party solutions (Wiz, etc.)
- No experience



1. Introduction and adoption of CSPM

Microsoft Defender for Cloud

as of 04/2025



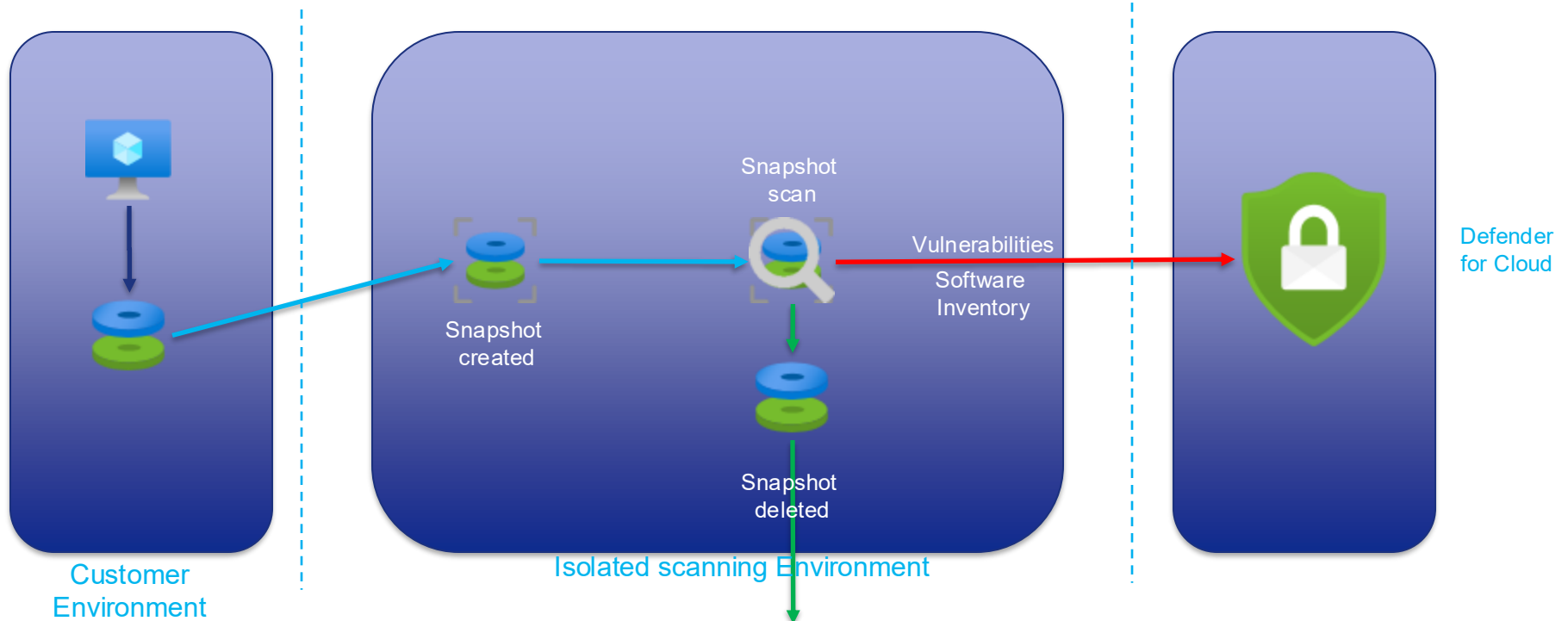


Foundational vs Defender for CSPM

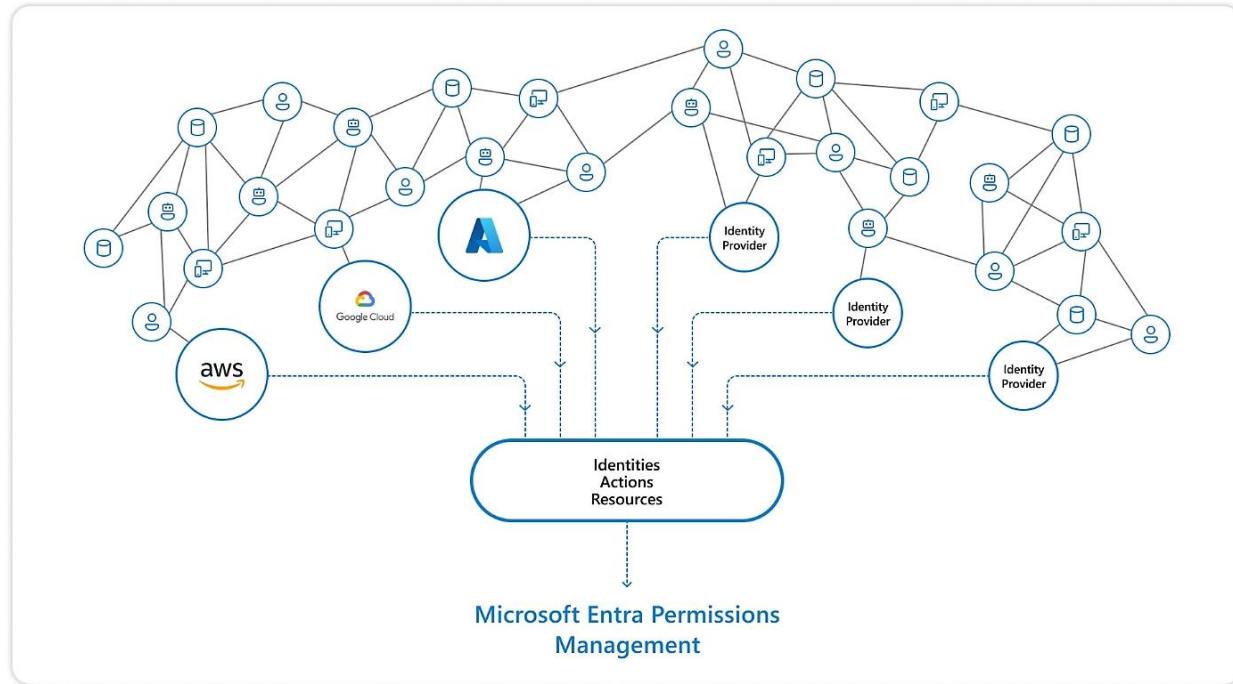
Features	Foundational CSPM	Defender for CSPM
Security recommendations to fix misconfigurations	✓	✓
Asset inventory	✓	✓
Secure score	✓	✓
Data exporting	✓	✓
Workflow automation	✓	✓
Tools for remediation	✓	✓
Microsoft Cloud Security Benchmark	✓	✓
Governance		✓
Regulatory compliance		✓
Cloud security explorer		✓
Attack path analysis		✓
Agentless scanning for machines		✓
Agentless discovery for Kubernetes		✓
Agentless VM secret scanning		✓
Data aware security posture		✓



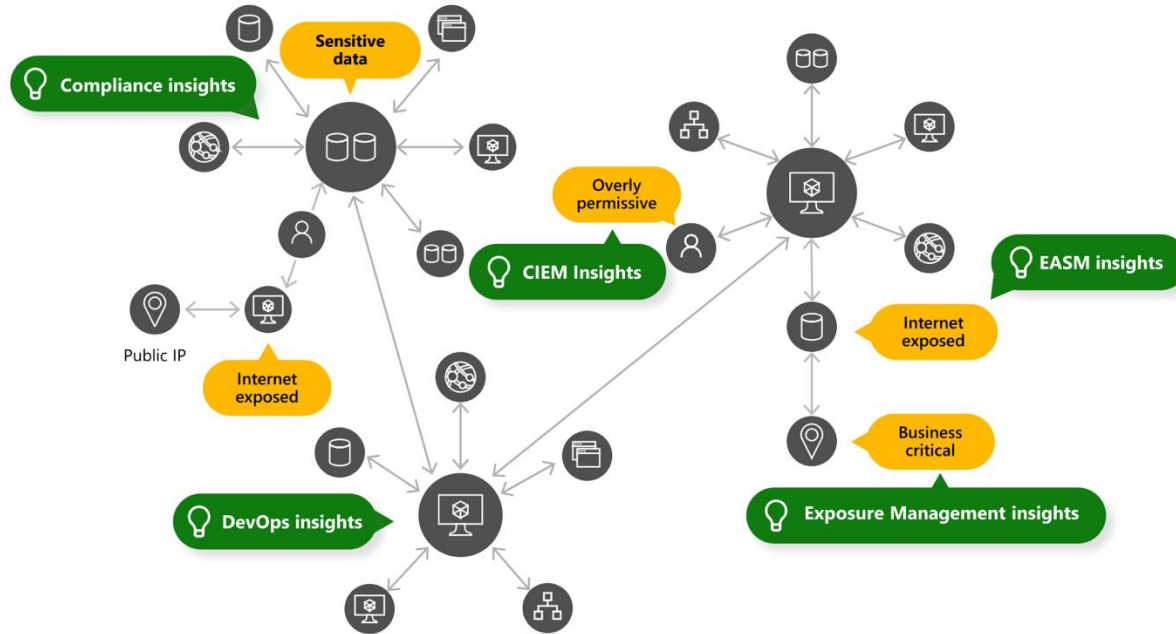
How Agentless scanning works



Cloud Infrastructure Entitlement Management



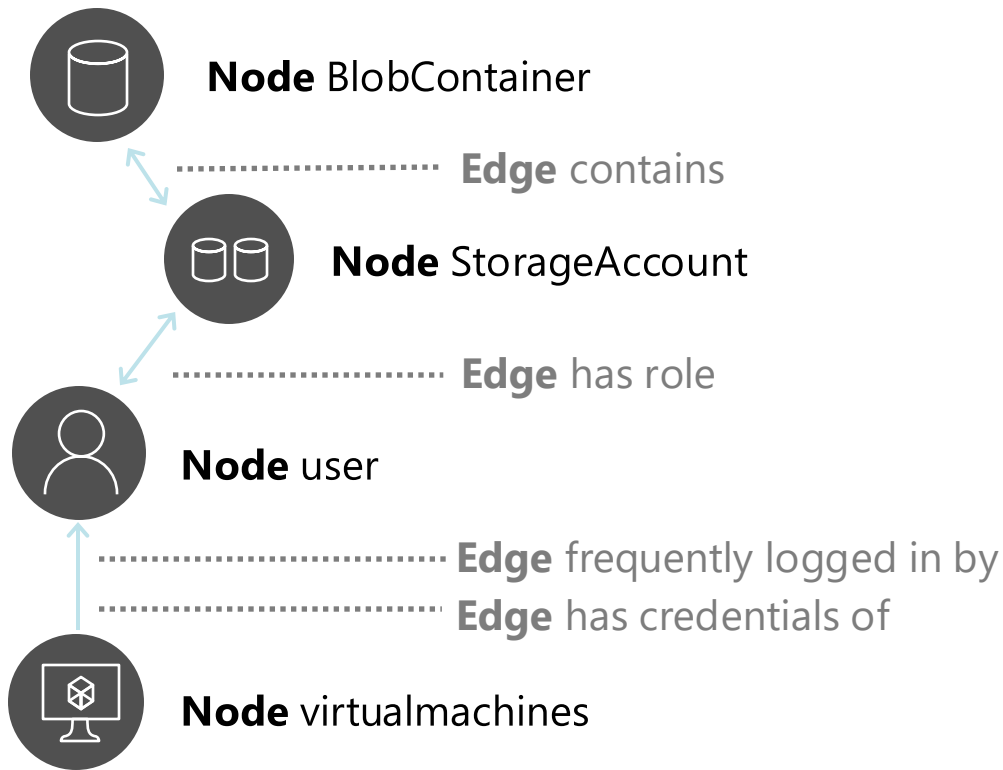
Contextual Security posture management



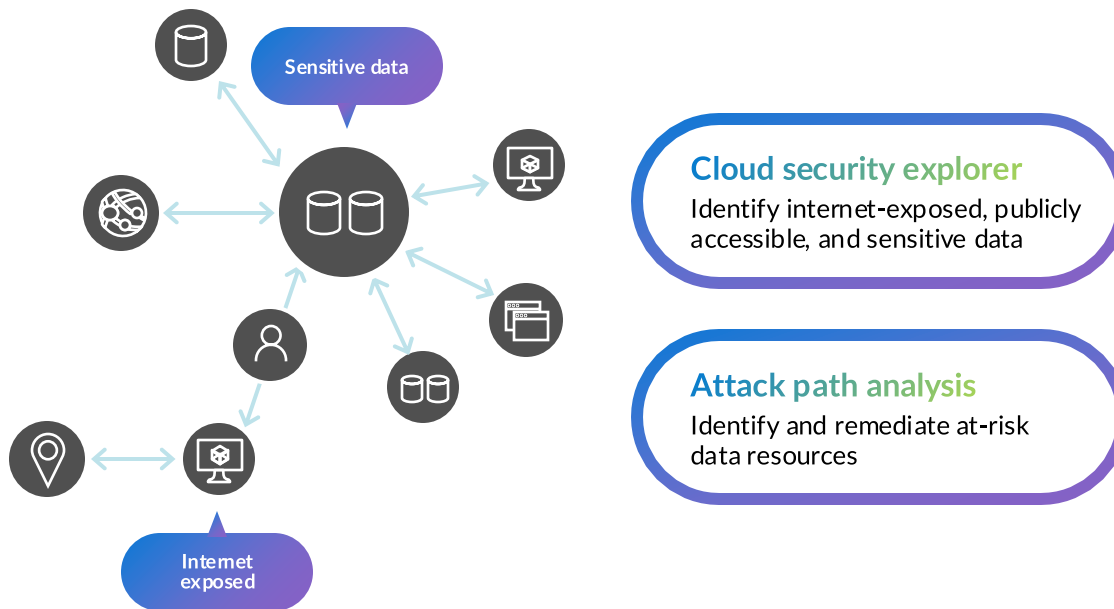


2. Risk prioritization with Attack Path Analysis

Security Graph overview



Use cases for „Cloud security graph“



Cloud Security Explorer

[Dashboard](#) > [Microsoft Defender for Cloud](#)

 **Microsoft Defender for Cloud** | Cloud Security Explorer ...

Showing 10 subscriptions

[»](#) [Share query link](#) [Download CSV report](#) [Guides & Feedback](#)

 **What would you like to search?**

[Query builder](#) [Templates](#)

**ADO and Github containing a vulnerability**

ADO and Github repositories containing code vulnerable to Apache Parquet vulnerability CVE-2025-30065

[Open query >](#)

**Container images vulnerable to Apache Parquet vulnerability CVE-2025-30065**

Returns all container images which are vulnerable to Apache Parquet vulnerability CVE-2025-30065

[Open query >](#)

**Internet exposed VMs**

Returns all internet exposed virtual machines

[Open query >](#)

**Internet exposed VMs with high severity vulnerabilities**

Returns all internet exposed virtual machines that have high severity vulnerabilities

[Open query >](#)

**VMs vulnerable to a specific vulnerability**

Returns all internet exposed virtual machines vulnerable to Log4Shell vulnerabilities

[Open query >](#)

Cloud Security Explorer



What would you like to search?

[Query builder](#) [Templates](#)

16 groups selected

AND

That

Allows public access

+ x Remove

That

Exposed to the internet

+ x Remove

Clear all

Scope : All  Partial results expected ⓘ

Search

Search

Showing 1 to 2 of 2 records.

Resource type	Resource name	Insights	
 Blob storage co...	corp	Allows public access Exposed to the internet	View details >
 Blob storage co...	uxcustom	Allows public access Exposed to the internet	View details >

Cloud Security Explorer

Dashboard > Microsoft Defender for Cloud



Microsoft Defender for Cloud | Cloud Security Explorer

Showing 10 subscriptions

» [Share query link](#) [Download CSV report](#) [Guides & Feedback](#)

4 resource types selected

That

Has vulnerabilities

Where

Severity

Equals

Critical

Remove

AND

That

Can authenticate as

Application identities (group)

That

Has permissions to

11 groups selected

Remove

Scope : All Partial results expected ⓘ

Search

Search

Showing 1 to 2 of 2 records.

Resource type	Resource name	CVE-ID	Connection	Resource type	Resource name	Connection	Resource type	Resource name	
Virtual machine	bapp-vm	CVE-2024-3009...	Can authenticat...	Managed i...	eee868e3-5469...	Has permission...	Key vault	bapp-kva	View details >
Virtual machine	vsaw-0	CVE-2024-3009...	Can authenticat...	Managed i...	aaa1b86f-1b72...	Has permission...	Key vault	identityops-kva	View details >

(No) API support for Security Explorer?

```
PS /home/thomas> $Query = @'
>> {
>>   "query": "Nodes
>>   | where Label in~ ('microsoft.keyvault/vaults')
>>   | where isempty(Properties.lastSeen) or todatetime(Properties.lastSeen) > ago(14d)
>>   | extend node_0 = bag_pack_columns(Id, Label, Name, Properties, EntityIds, EntityIdsDictio
nary, Categories), joinId_0 = Id
>>   | project-keep node_*, edge_*, findings_*
>>   | order by tolower(node_0.Name) asc"
>> }
>> '@
PS /home/thomas> $Params = @{
>>   Path = "providers/Microsoft.Security/query?api-version=2025-02-01-preview"
>>   Payload = $($Query)
>>   Method = 'POST'
>> }
PS /home/thomas> $Result = Invoke-AzRestMethod @Params
```



Attack Path calculation and scenarios

Azure VM with high severity vulnerabilities allows lateral movement to Critical Azure storage account with sensitive data

High

1
Active Recommendations

Azure

Attack story

1- Attacker with network access to the VM can exploit the vulnerabilities and gain control on it
2- Attacker can authenticate as the managed identity
3- Attacker can use the identity to read data from the storage account
4- Attacker ca...

[Show more](#)

Resource types

- Managed identity (1)
- Storage account (1)
- Virtual machine (1)

Risk factors

CRITICAL RESOURCE VULNERABILITIES LATERAL MOVEMENT SENSITIVE DATA

MITRE ATT&CK® tactics

Lateral Movement [Read more](#)

Remote Services (T1021)
Cloud Services (T1021/007)

Attack path

Remediation

Entry point

Target

```
graph LR; VM[Virtual machine] -- "can authenticate as" --> MI[Managed identity]; MI -- "has permissions to" --> SA[Storage account];
```

[Give us feedback](#)

Integration to MDC Recommendations

[Dashboard](#) >

Windows servers should be configured to use secure communication protocols ...

[Open query](#) [View policy definition](#) [View recommendation for all resources](#)

Critical
Risk level ⓘ

vsaw-0
Resource

Overdue
Status

Description

To protect the privacy of information communicated over the Internet, your servers should use the latest version of the industry-standard cryptographic protocol, Transport Layer Security (TLS). TLS secures communications over a network by using security certificates to encrypt a connection between machines.

Attack Paths
 0

Scope
 Platform - Iden...

Freshness
 30 Min

Last change date
4/2/2023

Owner
 admThom0@lab.cl...

Due date
4/16/2023

Ticket ID
-

Risk factors ⓘ

VULNERABILITIES CRITICAL RESOURCE SENSITIVE DATA +1

Take action **Graph**

Below you can find all attack paths and resource context that used to determine the risk level of this recommendation:

Additional context (4)

vsaw-0
Entry point

→

identityops-kva
Target

```
graph LR; A["vsaw-0 Virtual machine"] -- "can authenticate as" --> B["aaa1b86f-1b72-4211... Service Principal"]; B -- "has permissions to" --> C["identityops-kva Key vault"]
```

Microsoft

TD SYNnex

Capgemini

inforcenter

DELL Technologies

nerdio

Professional Development Systems BV

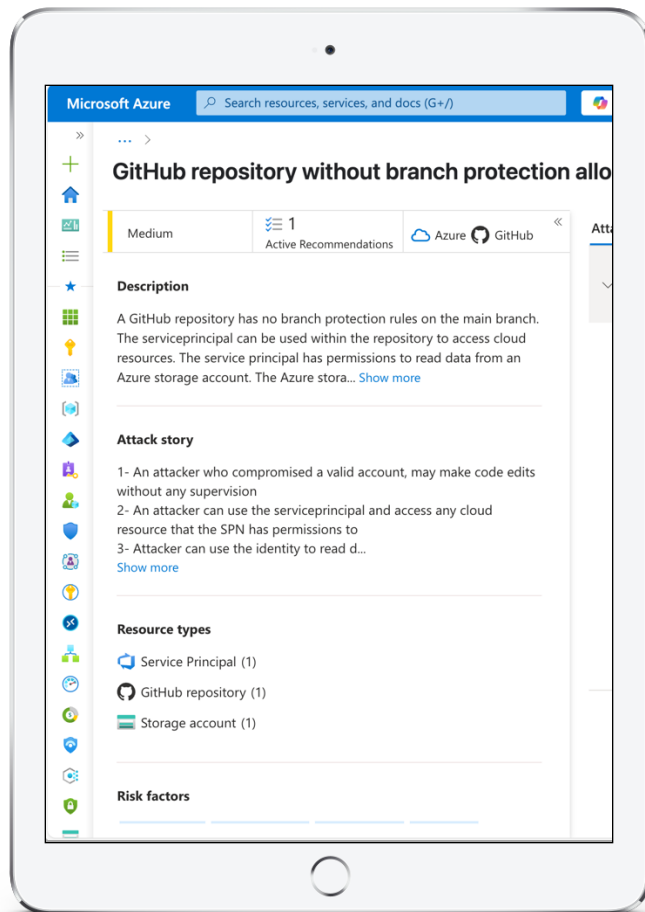
INTERSTELLAR

kpn Partner Network

INSPARK

cegeka

Demo + Attack Paths and CSPM



Enhancing Incident Triage Efficiency

Playbooks

Runs

Select a playbook to run now on the incident. Only enabled playbooks configured with the Microsoft Sentinel incident trigger can be triggered.

Search by name

Subscription : AIA External - WIZLABS

More (2)

↑↓	Name ↑↓	Subscription ↑↓	Resource group ↑↓	Plan ↑↓	
☆	attack-path-sentinel-incident-enrich	🔑 AIA External - WI...	🖥️ rg-wizlabs-env-01	Consumption	Run
☆	Incident-get-mdc-recommendatio...	🔑 AIA External - WI...	🖥️ rg-wizlabs-env-01	Consumption	Run
☆	Incident_Remediation_Help	🔑 AIA External - WI...	🖥️ rg-wizlabs-env-01	Consumption	Run

→ [Microsoft Sentinel Playbook Template](#)

→ [Security Copilot Custom Plugin](#)



Comment created from playbook - attack-path-sentinel-incident-enrich 06/12/23, 01:22 PM



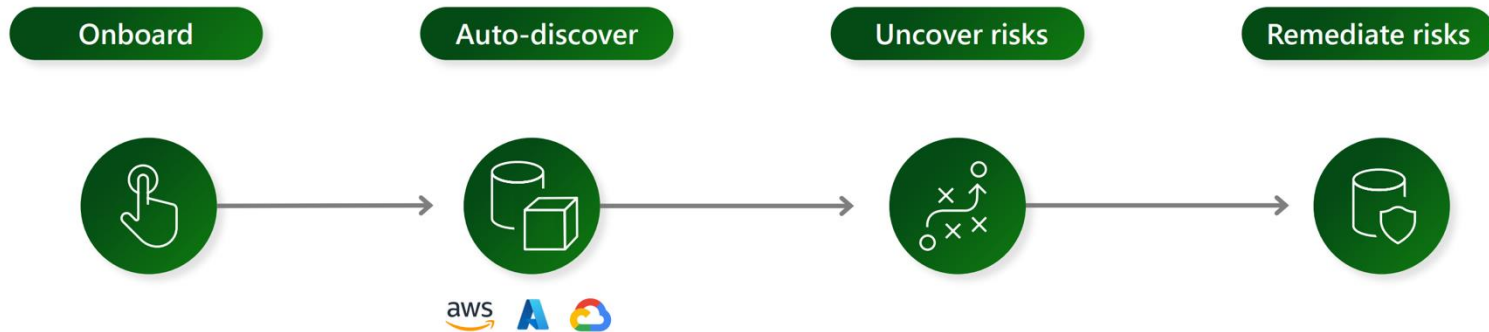
Defender for Cloud has identified the following possible Attack Paths where the resource mydemoW2019-002 is a node of:

1. SQL on VM 'mydemow2019-002' is reachable from the internet, has a local user account with commonly used username (which is prone to brute force attacks), and has known vulnerabilities (CVEs)
2. SQL on VM 'mydemow2019-002' is reachable from the internet, has a local user account with commonly used username (which is prone to brute force attacks), and has vulnerabilities allowing code execution and lateral movement to the underlying VM
3. Virtual machine 'mydemow2019-002' is reachable from the internet and has high severity vulnerabilities allowing remote code execution on the machine
4. Virtual machine 'mydemow2019-002' is reachable from the internet, has high severity vulnerabilities allowing remote code execution on the machine and assigned with Managed Identity with read permission to Key Vault 'gastorimydemokeyvault002'



3. Data-aware security posture (DSPM)

Data-aware security posture



Agentless onboarding of multicloud data resources, one-click enablement

Automatically discover your cloud data estate to surface accessibility, sensitive data, and data flows

Uncover risks to your data resources through the cloud security explorer and attack path analysis

Strengthen your cloud data security posture with built-in insights, recommendations, and quick fixes



4. Advanced scenarios with Exposure Management and APIs

XDR, SIEM and XSPM

Unified Threat
Management
(XDR/SIEM)

Detect

Response

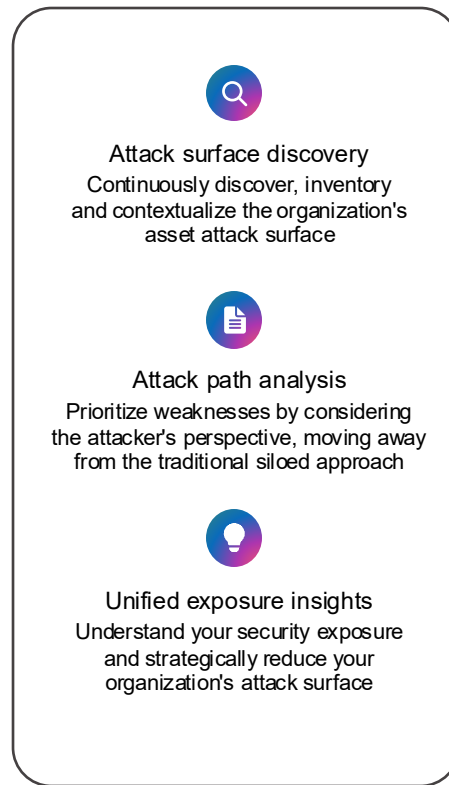
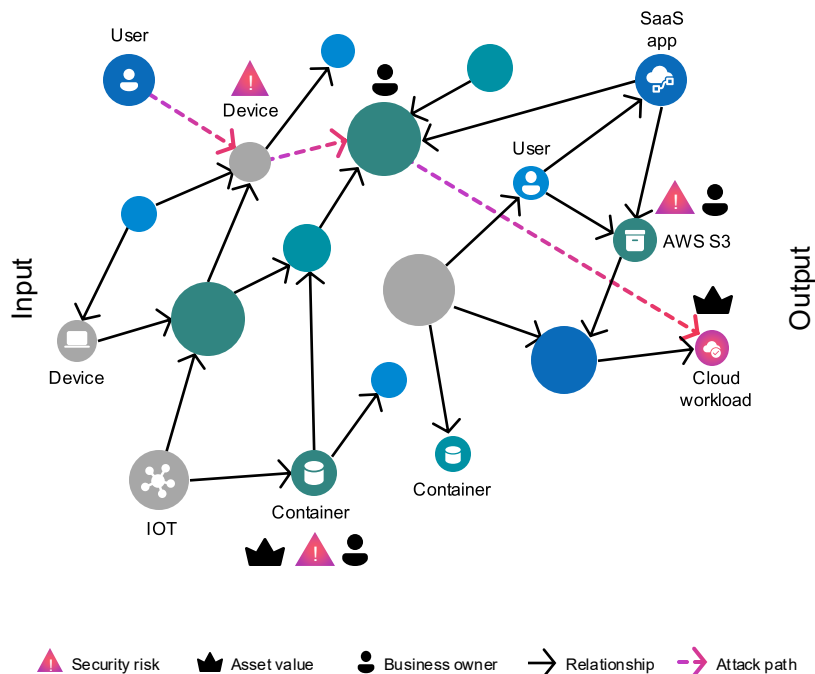
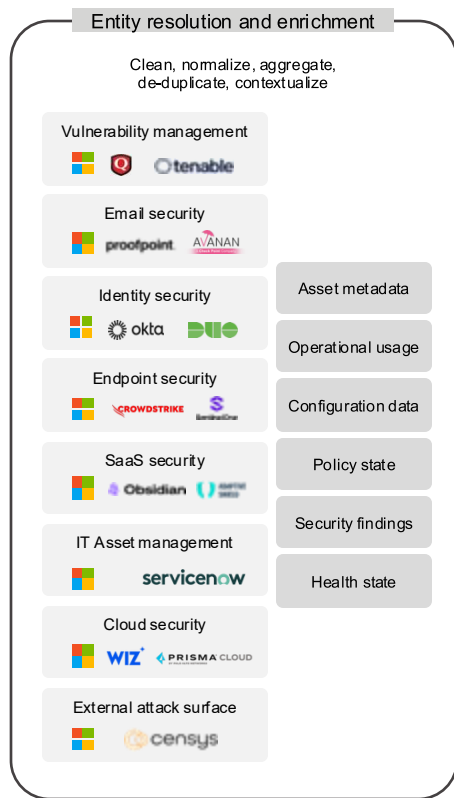
Unified Exposure
Management
(XSPM)

Identify

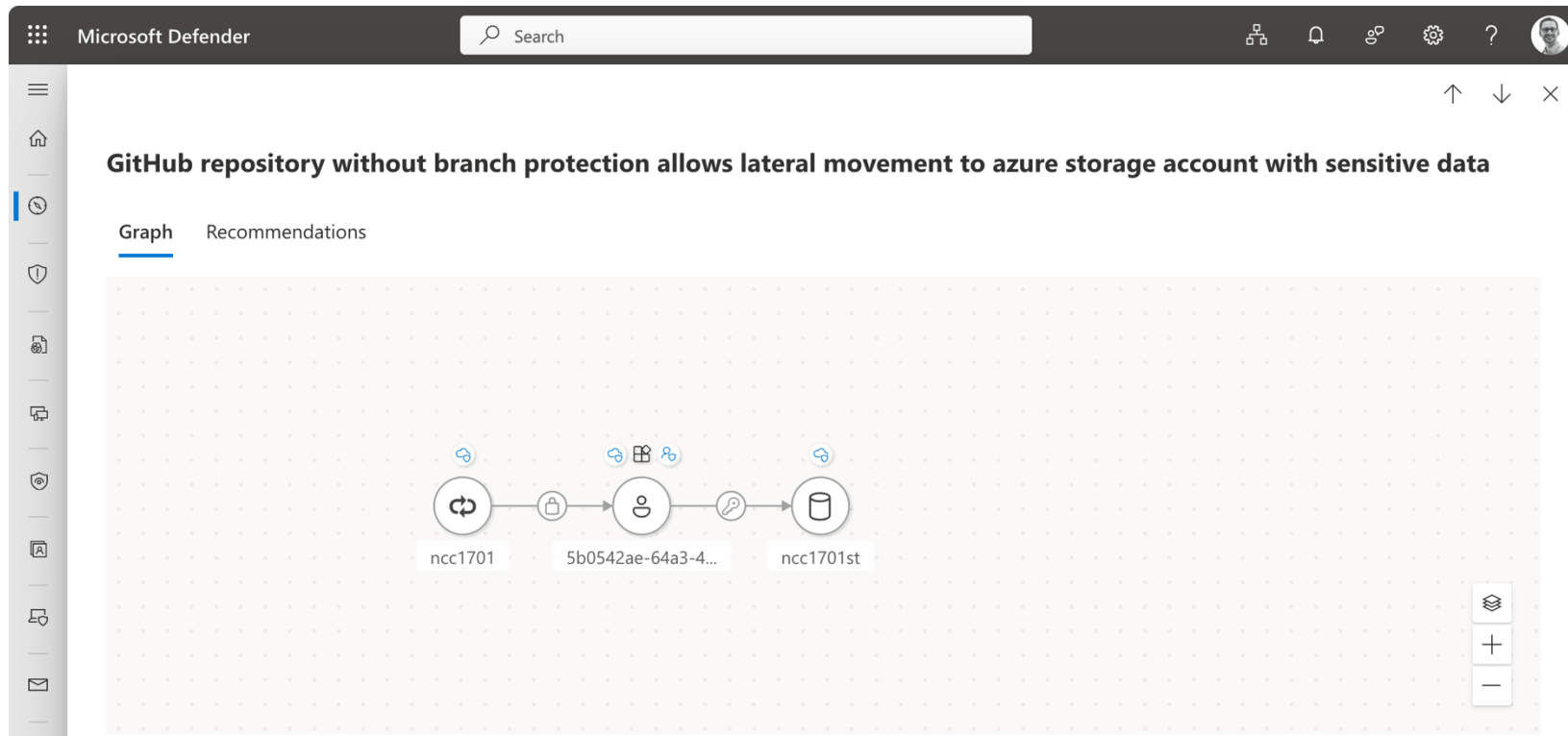
Protect

Holistic pre- and post-breach view and data

Exposure Management



Compare Attack Path in MDC vs. XSPM



Attack Path from Azure VM in MDC CSPM

Microsoft Azure Search resources, services, and docs (G+/) Copilot thomas@cloud-architek... CLOUDLAB (CLOUD-ARCHITEK...

Dashboard > Microsoft Defender for Cloud | Attack path analysis >

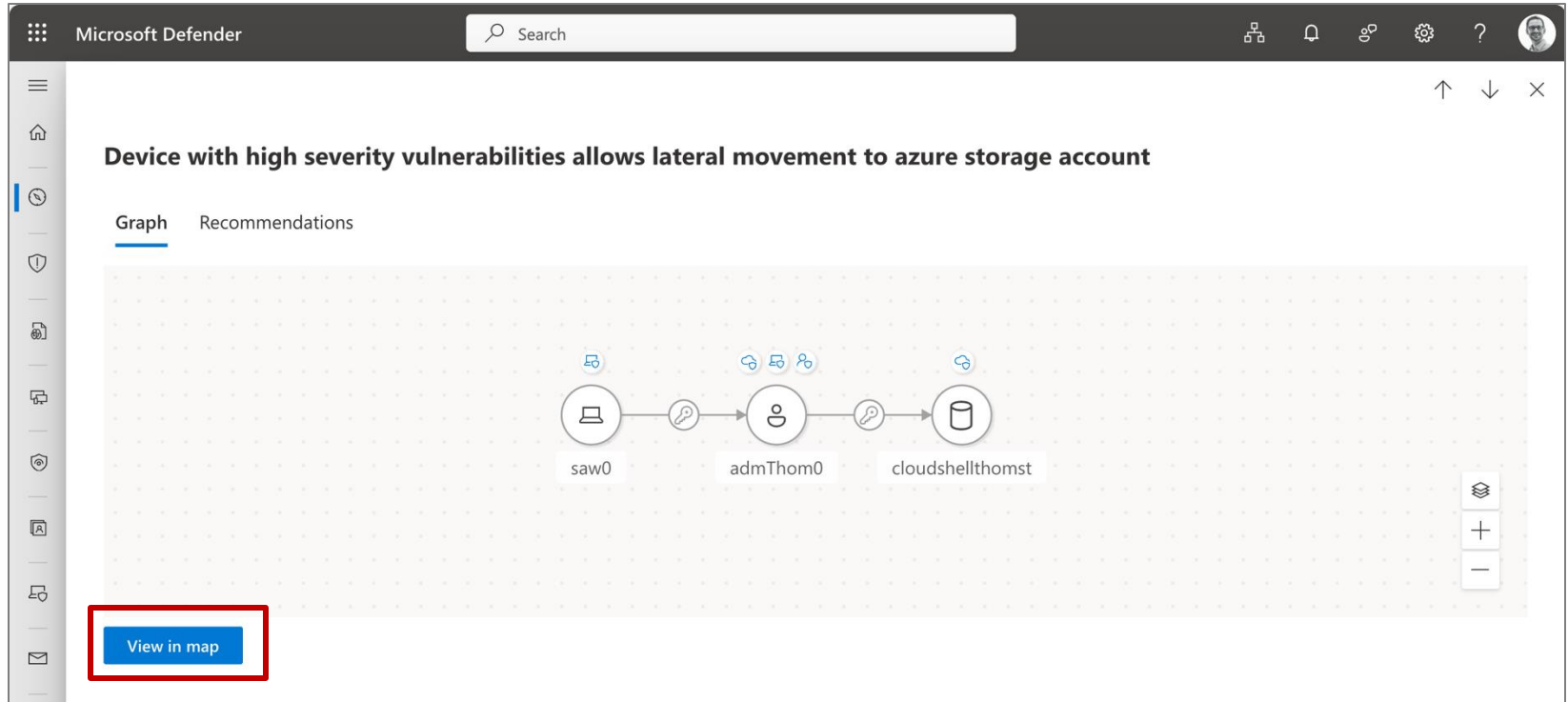
Azure VM with high severity vulnerabilities allows lateral movement to Critical Azure Key Vault

Attack path Remediation

```
graph LR; VM[aadops1-vm.x1lr1pd... Virtual machine] -- "can authenticate as" --> MI[854818f0-bbbd-45df... Managed identity]; MI -- "has permissions to" --> KV[identityops-kva Key vault];
```

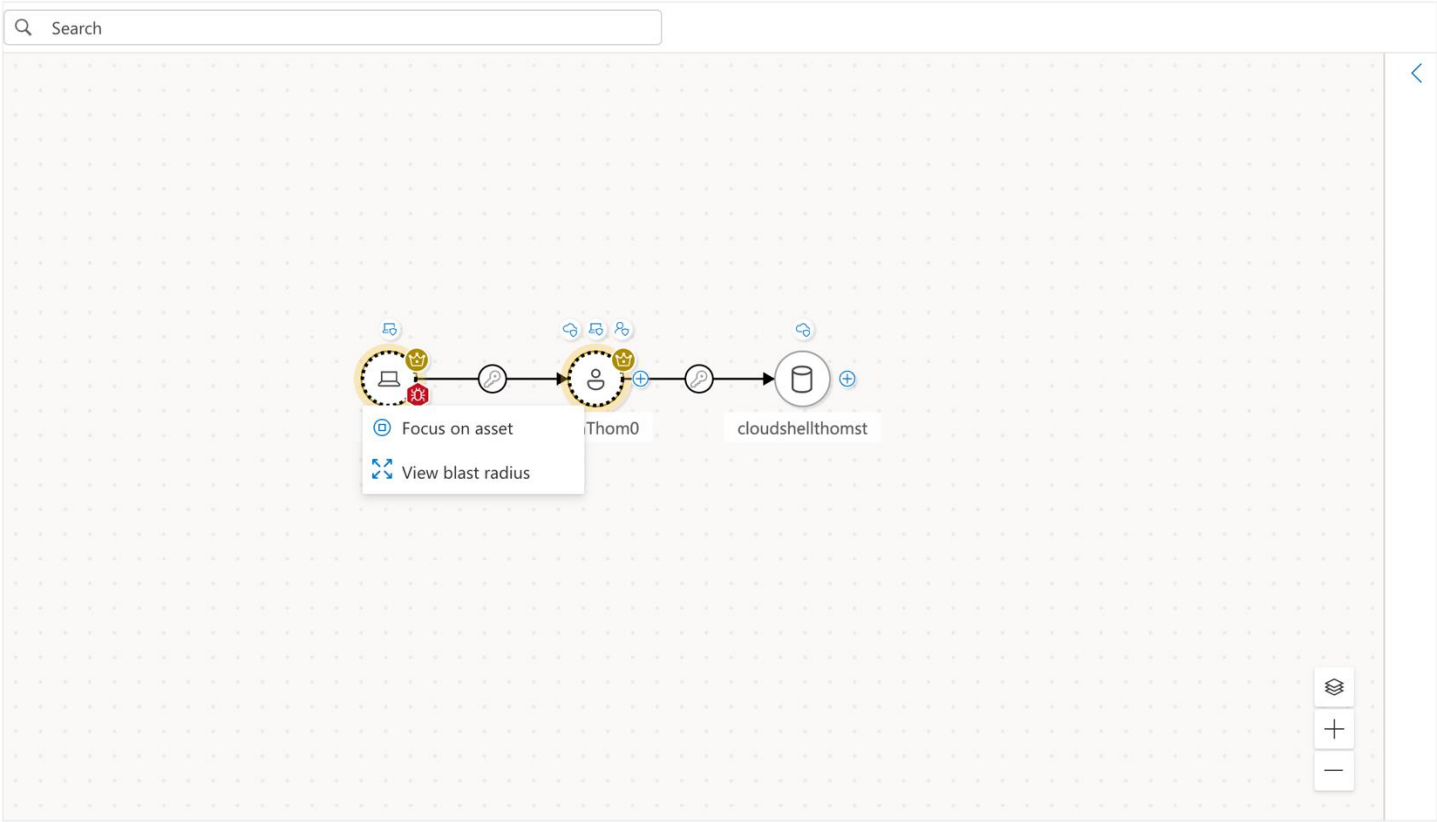
The diagram illustrates an attack path starting from a Virtual machine (aadops1-vm.x1lr1pd...) which can authenticate as a Managed identity (854818f0-bbbd-45df...). This Managed identity has permissions to access a Key vault (identityops-kva). The Key vault is highlighted with a red circle, indicating it is a critical target. To the right of the diagram is a small image of a person holding their head in their hands, suggesting a state of distress or frustration.

Attack Path from device in XSPM



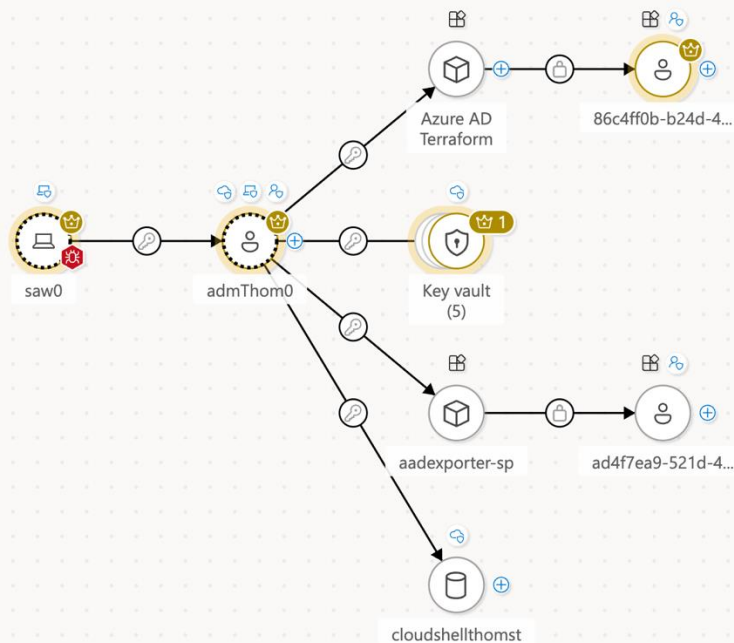


Attack surface map



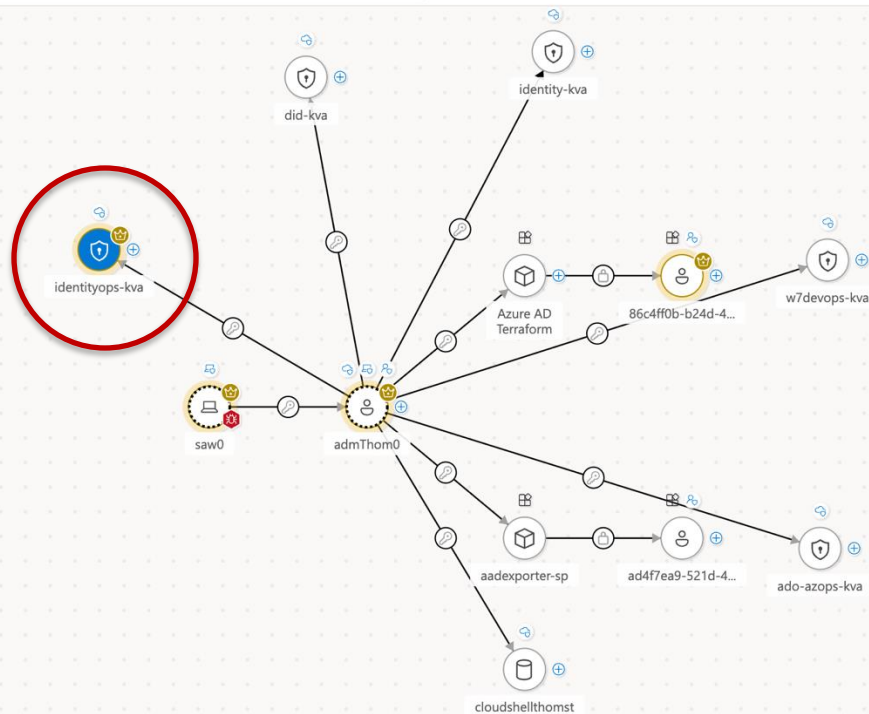
Attack surface map

Search

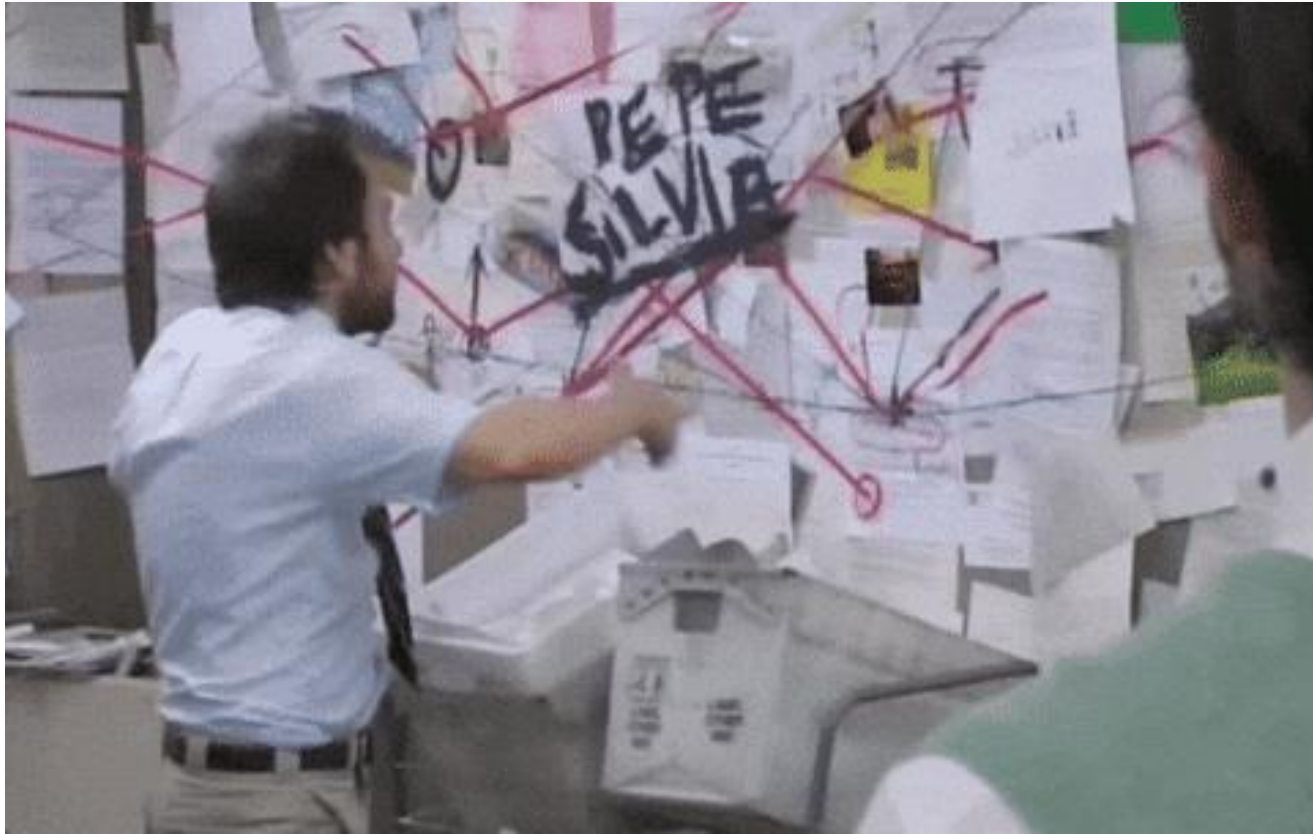


Attack surface map

Search

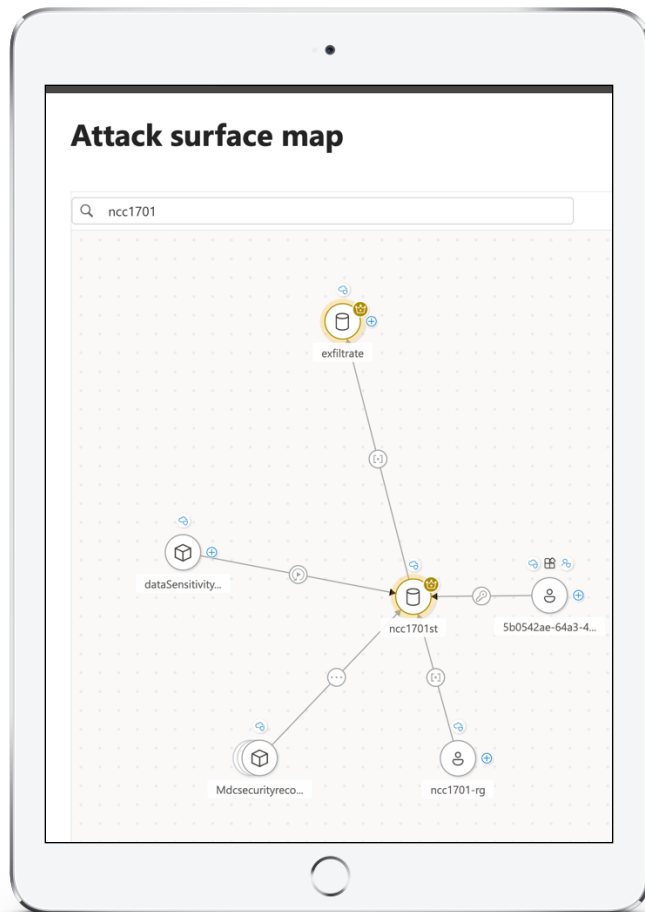


Attack Surface Map Navigation



Demo

Attack Map, Graph and Critical Assets



Integrations of Critical Assets in Security Explorer

Code repositories (group), CI/CD Pipeli... 

That Criticality Level  **Where** Resource criticality level **Equals** Very high - tier 0

Scope : All  Partial results expected  

 Search

Showing 1 to 1 of 1 records.

Resource type	Resource name	Connection	Resource type	Resource name	Resource critic...	Insights
 ADO Project	aadb2c	Contains	 ADO Repo...	aadb2c	Very high - tier 0	Criticality Level View details >

Challenges in Critical Asset

- Operationalize of approval flow for assets
- Rule logic can be inaccurate
- No individual exclude or adjustment of pre-defined classification
- Time until classification applies and affects attack path calculation
- Granular Containment of Critical Assets

Domain Controllers

✕ Turn off

Overview

Assets

Pending Approval ●

We believe the assets listed below could be considered critical for your organization, however, we require your input for confirmation.

4 items

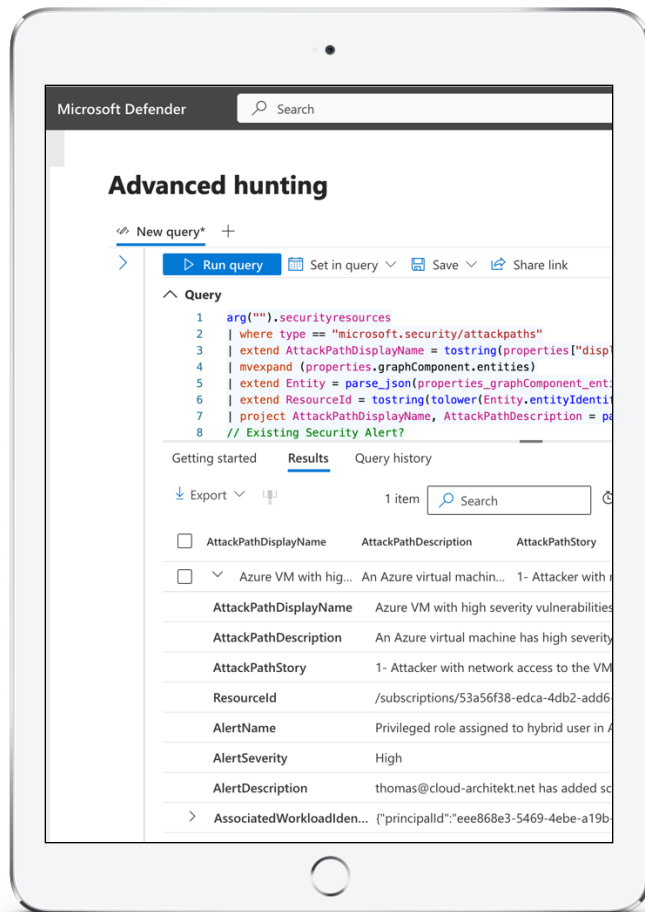
Asset name	Date found		
s3	4/21/2025	● New	+
s6	4/21/2025	● New	+



Limitations on Cross Tenant and API access

- Limitations on GDAP and B2B access
- No programmatically access to Attack Paths
- *but...*

Demo + Hunting with. CSPM & Unified XDR



Defender for CSPM Pricing

Billable workloads will be



Virtual Machines
(except Deallocated VMs)



Storage Accounts
(Blob and Fileshares)



Azure Databases
PostgreSQL | MySQL
MariaDB | Synapse



SQL Server
Azure VMs and
Managed Instances



EC2 instances
(except Deallocated VMs)



S3 buckets



RDS Instances



Compute
Instances

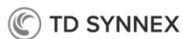


Storage buckets



Cloud SQL Instances

Price **\$4.733** per billable resource/month



[Cloud Security Posture Management \(CSPM\) - Microsoft Defender for Cloud | Microsoft Learn](#)



Please evaluate this session in the App.

THANK YOU

Are there any questions?





Next session 15:25 – 16:15

Two voices, one view - How to choose between
Microsoft AVD and Windows 365 Cloud PC

